

Annual Re-Attestation Pack

Document ID	Version	Owner	Effective Date	Framework	Classification
[DOC-ID]	1.0	[CISO / SWIFT Security Officer]	[Effective Date]	SWIFT Customer Security Controls Framework	Confidential - Internal Use Only

Purpose

This Annual Re-Attestation Pack records the organisation's formal yearly attestation regarding its implementation and operation of the SWIFT Customer Security Controls Framework for the attestation cycle running from July to December.

The purpose of this document is to:

- Confirm management's accountability for the accuracy and completeness of the annual SWIFT security attestation.
- Provide a structured record of the control self-assessment, supporting evidence, approvals and sign-off.
- Demonstrate that the organisation has reviewed the security posture of its SWIFT environment against applicable SWIFT security expectations.
- Support internal governance, independent review, external assurance activities and regulatory or correspondent banking due diligence where required.
- Maintain an auditable record of decisions, exceptions, compensating measures and remediation commitments associated with the annual re-attestation.

This document is intended to be used as the formal attestation record for the annual cycle and as the summary pack retained with the supporting evidence repository.

Scope

This attestation applies to the organisation's SWIFT environment, including the people, processes, technology, facilities, connectivity and third parties involved in the secure use, administration, operation and support of SWIFT services.

The in-scope environment includes:

Scope Area	Included Components
SWIFT connectivity	SWIFT interfaces, messaging connectivity, connectivity providers, network routes and related gateways
SWIFT infrastructure	Servers, workstations, virtual infrastructure, middleware, databases, storage and backup components supporting SWIFT operations
Secure zones	Segmented network areas, operator workstations, jump servers, administrative access paths and security boundaries protecting SWIFT components
Identity and access management	User accounts, privileged accounts, administrator access, authentication mechanisms, periodic access reviews and joiner-mover-leaver activities
Operational security	Change management, vulnerability management, patching, malware protection, logging, monitoring, incident response and backup procedures
Physical and environmental security	Data centre, operations rooms, restricted areas and physical access arrangements for SWIFT-related assets
Third-party services	Outsourced operations, hosting, managed security services, support providers and any third party with access to, or responsibility for, SWIFT-related assets
Governance and oversight	Policies, standards, risk assessments, management review, exception handling and remediation tracking relevant to the SWIFT environment

The attestation covers the status of control design and operating effectiveness as at the annual attestation date, taking into account evidence reviewed during the July-December cycle.

The following are excluded unless they directly affect the SWIFT environment:

- Corporate systems with no connectivity to, administrative path into, or operational dependency with SWIFT services.
- General business applications that do not process, generate, approve, transmit, receive or reconcile SWIFT messages.
- Third-party systems where the organisation has no contractual responsibility or operational control, except where reliance on those services is material to SWIFT security.

Where any exclusion, boundary decision or dependency materially affects the attestation, it must be documented in the evidence pack and approved by the signatory.

Attestation Statement

On behalf of [Organisation Name], I attest that the organisation has completed its annual review of the security controls applicable to its SWIFT environment for the July-December re-attestation cycle.

Based on management review, control owner confirmations, evidence inspection and recorded exception analysis, the organisation confirms that:

- The SWIFT environment has been identified, documented and reviewed for completeness.
- The applicable SWIFT security requirements have been assessed against the organisation's implemented control environment.
- Control owners have provided confirmation of control implementation status and operating effectiveness for the areas under their responsibility.
- Supporting evidence has been collected, reviewed and retained in accordance with this pack.
- Any identified gaps, exceptions, compensating controls or remediation actions have been recorded, risk-assessed and assigned to accountable owners.
- Material changes to the SWIFT environment during the attestation period have been reviewed for security impact.
- Management has reviewed the attestation outcome and accepts the stated position as accurate to the best of its knowledge.
- No known material misstatement, omission or unresolved high-risk issue has been intentionally excluded from this attestation.

The organisation's attestation outcome for the current cycle is recorded below:

Attestation Item	Response
Organisation legal name	[Organisation Name]
SWIFT BIC / identifier	[BIC / SWIFT Identifier]
Attestation cycle	July-December [Year]
Attestation date	[Date]
Overall attestation status	[Compliant / Compliant with Exceptions / Non-Compliant / Not Applicable]
Independent assessment performed	[Yes / No]
Independent assessor	[Internal Audit / External Assessor Name / Not Applicable]
Material exceptions identified	[Yes / No]
Remediation plan required	[Yes / No]

Attestation Item	Response
Executive risk acceptance required	[Yes / No]
Date submitted to SWIFT platform	[Date / Pending]
Submitted by	[Name / Role]

Where the outcome is recorded as **Compliant with Exceptions** or **Non-Compliant**, the following table must be completed:

Exception ID	Control Area	Description of Gap	Business Impact	Compensating Measure	Risk Rating	Remediation Owner	Target Date	Current Status
[EX-001]	[Area]	[Description]	[Impact]	[Measure]	[Low / Medium / High / Critical]	[Owner]	[Date]	[Open / In Progress / Closed]

Management acknowledges that this attestation is not a one-time compliance exercise. The organisation is expected to maintain the required security posture throughout the year and to escalate material changes, incidents or control failures that could affect the SWIFT environment.

Signatory & Authority

This attestation must be signed by an authorised executive with sufficient accountability for the organisation's SWIFT security posture, supported by the designated SWIFT Security Officer, technology control owners and relevant risk or compliance stakeholders.

The authorised signatory must have authority to:

- Confirm the accuracy of the annual SWIFT security attestation.
- Accept residual security risk within the organisation's governance structure.
- Approve remediation commitments and ensure appropriate resources are allocated.
- Require corrective action from control owners and service providers.
- Escalate material risk issues to senior management, the risk committee or board-level governance forum where required.

The following approvals are required before submission of the annual re-attestation:

Role	Responsibility	Name	Approval Date	Signature / Approval Reference
Executive Signatory	Final accountability for attestation accuracy and residual risk acceptance	[Name]	[Date]	[Signature / e-Approval ID]
SWIFT Security Officer	Confirms completeness of SWIFT security review and evidence pack	[Name]	[Date]	[Signature / e-Approval ID]
Chief Information Security Officer	Confirms security control review, exception assessment and remediation oversight	[Name]	[Date]	[Signature / e-Approval ID]
Head of Technology / Infrastructure	Confirms technical control implementation and operational status	[Name]	[Date]	[Signature / e-Approval ID]
Head of Operations / Payments	Confirms operational process controls and user procedures	[Name]	[Date]	[Signature / e-Approval ID]
Risk / Compliance Representative	Confirms governance review, risk recording and policy alignment	[Name]	[Date]	[Signature / e-Approval ID]
Internal Audit / Independent Reviewer	Confirms independent review outcome, where applicable	[Name]	[Date]	[Signature / e-Approval ID]

By signing this attestation, the Executive Signatory confirms that:

- The attestation has been prepared using a reasonable and evidence-based assessment process.
- Material control issues known at the date of signature have been disclosed.
- Exceptions and remediation plans have been reviewed and are subject to management tracking.
- The organisation will retain adequate evidence to support the submitted attestation.
- Any material change affecting the SWIFT security posture after signature will be escalated through the organisation's risk governance process.

Final sign-off:

Statement	Confirmation
I confirm that I am authorised to approve this annual SWIFT security re-attestation on behalf of [Organisation Name].	[Yes / No]
I confirm that the information contained in this pack is accurate and complete to the best of my knowledge.	[Yes / No]
I confirm that all known material exceptions have been disclosed and are being managed.	[Yes / No]
I approve submission of the attestation outcome for the July-December [Year] cycle.	[Yes / No]

Executive Signatory: [Name] **Title:** [Title] **Date:** [Date] **Signature / Approval Reference:** [Signature / e-Approval ID]

Evidence Referenced

The attestation must be supported by evidence sufficient to demonstrate that required security controls are designed, implemented and operating effectively. Evidence must be current, relevant, complete, traceable to the SWIFT environment and retained in a controlled repository.

Evidence must not consist only of policy statements unless the control being assessed is purely governance-based. Operational controls require proof of performance, such as system extracts, review records, tickets, logs, screenshots, signed approvals or independent test results.

The evidence pack for this attestation includes, at minimum:

Evidence Category	Required Evidence	Evidence Owner	Repository Location	Review Status
SWIFT environment inventory	Current list of SWIFT applications, servers, workstations, network devices, interfaces and dependencies	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Network architecture	Current diagrams showing SWIFT zones, segmentation, firewalls, connectivity flows and administrative paths	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
User access records	Current SWIFT user list, administrator list, privileged access approvals and access review results	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Authentication controls	Evidence of strong authentication for users, administrators and remote access paths	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Privileged access management	Privileged account inventory, approval records, session controls and periodic review results	[Owner]	[Link / Repository Path]	[Reviewed / Pending]

Evidence Category	Required Evidence	Evidence Owner	Repository Location	Review Status
Change management	Change tickets for material SWIFT environment changes, approvals, testing evidence and implementation records	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Vulnerability management	Latest vulnerability scans, remediation tracking, exception approvals and patch status for in-scope assets	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Malware protection	Endpoint protection status, coverage reports, alert handling records and update status	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Logging and monitoring	Log source coverage, monitoring rules, alert review evidence and incident escalation records	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Backup and recovery	Backup schedules, successful backup reports, restoration test evidence and recovery procedures	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Incident response	SWIFT-related incident response procedures, contact lists, test records and incident logs for the cycle	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Physical security	Access lists, restricted area controls, visitor records and periodic access reviews for SWIFT locations	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Third-party assurance	Supplier contracts, access arrangements, service assurance reports, security attestations and issue tracking	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Security awareness	Training completion evidence for SWIFT operators, administrators and relevant support staff	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Risk and exception management	Risk assessments, exception approvals, compensating control records and remediation plans	[Owner]	[Link / Repository Path]	[Reviewed / Pending]
Independent review	Internal audit, external assessment or second-line review reports, where performed	[Owner]	[Link / Repository Path]	[Reviewed / Pending]

Evidence quality must be assessed using the following criteria:

Quality Criterion	Requirement
Relevance	Evidence must directly relate to the SWIFT environment and the control being assessed.
Currency	Evidence must reflect the current attestation cycle or the most recent completed control activity.
Completeness	Evidence must cover all relevant in-scope assets, users, processes or service providers.
Integrity	Evidence must be obtained from authoritative systems or approved business records.
Traceability	Evidence must be linked to the control assessment, reviewer and approval record.
Confidentiality	Evidence containing sensitive security or customer information must be protected from unauthorised access.

The evidence review log must be completed before final sign-off:

Evidence Ref	Evidence Description	Reviewer	Review Date	Result	Comments / Follow-Up
[EV-001]	[Description]	[Name]	[Date]	[Accepted / Rejected / Follow-Up Required]	[Comments]
[EV-002]	[Description]	[Name]	[Date]	[Accepted / Rejected / Follow-Up Required]	[Comments]
[EV-003]	[Description]	[Name]	[Date]	[Accepted / Rejected / Follow-Up Required]	[Comments]

Evidence that is incomplete, outdated, inconsistent or not clearly linked to the SWIFT environment must be remediated before final attestation or documented as an exception with an assigned owner and target date.

Frequency

The organisation performs a formal SWIFT security re-attestation annually during the July-December cycle. The annual attestation must be completed, approved and submitted in line with the deadlines established by SWIFT and the organisation's internal governance calendar.

The standard annual timeline is:

Period	Activity	Accountable Role	Output
July	Confirm attestation scope, asset inventory, stakeholders and evidence repository structure	SWIFT Security Officer	Approved attestation plan
July-August	Issue control owner requests and confirm applicability of control areas	CISO / SWIFT Security Officer	Control owner confirmation list
August-September	Collect and review evidence for technical, operational and governance controls	Control Owners	Evidence pack and review log
September-October	Perform gap assessment, validate exceptions and identify remediation actions	Security / Risk / Compliance	Exception register and remediation plan
October-November	Conduct management review and, where applicable, independent review	CISO / Internal Audit / Independent Reviewer	Review report or management summary
November	Resolve evidence issues, approve compensating measures and confirm residual risk	Control Owners / Risk Owners	Updated exception and risk records
November-December	Obtain executive sign-off and submit annual attestation	Executive Signatory	Signed attestation and submission confirmation
December	Archive records and update improvement plan for the next cycle	SWIFT Security Officer	Retained attestation pack and lessons learned

In addition to the annual cycle, an interim review must be performed when any of the following occur:

- Significant change to SWIFT architecture, hosting model, connectivity or service provider arrangements.
- Introduction of new SWIFT messaging services or material change to transaction flows.
- Major security incident involving SWIFT systems, payment operations, privileged access or related infrastructure.
- Discovery of a material control failure or long-standing exception affecting the SWIFT environment.
- Significant organisational change affecting ownership, operating model, outsourcing or support responsibilities.
- Regulatory, supervisory, correspondent banking or board request for updated assurance.

Interim reviews do not replace the annual attestation unless formally approved by the Executive Signatory and aligned with SWIFT submission requirements.

Records & Retention

The completed Annual Re-Attestation Pack and all supporting records must be retained as controlled compliance records. Records must be sufficiently complete to allow an independent reviewer, auditor, regulator or authorised management representative to understand the basis of the attestation decision.

The following records must be retained:

Record Type	Minimum Retention Requirement	Record Owner	Storage Location
Signed annual attestation pack	[Retention Period, e.g. 7 years]	[Owner]	[Repository Path]
Submitted attestation confirmation	[Retention Period]	[Owner]	[Repository Path]
Evidence pack and review log	[Retention Period]	[Owner]	[Repository Path]
Control owner confirmations	[Retention Period]	[Owner]	[Repository Path]
Exception register and remediation plan	[Retention Period]	[Owner]	[Repository Path]
Risk acceptances and compensating control approvals	[Retention Period]	[Owner]	[Repository Path]
Independent assessment reports, where applicable	[Retention Period]	[Owner]	[Repository Path]
Management review minutes and approval records	[Retention Period]	[Owner]	[Repository Path]
Communications with SWIFT or external assessors relating to the attestation	[Retention Period]	[Owner]	[Repository Path]

Retention and handling requirements:

- Records must be stored in an access-controlled repository approved for confidential security and compliance information.
- Access must be limited to personnel with a legitimate business need, including security, risk, compliance, audit, technology operations and authorised executives.
- Evidence containing credentials, cryptographic material, sensitive infrastructure details or security monitoring information must be redacted or protected using enhanced access controls.
- Records must not be altered after final approval except through a controlled amendment process that preserves version history.
- Superseded drafts must either be retained in line with recordkeeping requirements or disposed of securely where retention is not required.
- Any evidence requested by auditors, regulators, SWIFT, correspondent banks or approved independent assessors must be released only through authorised channels.
- Disposal at the end of the retention period must be approved by the record owner and performed securely.

The SWIFT Security Officer is responsible for confirming that the final pack has been archived after submission. The record archive confirmation must be completed below:

Archive Item	Confirmation
Final signed attestation stored in approved repository	[Yes / No]
Supporting evidence pack stored and indexed	[Yes / No]
Exception and remediation records linked to risk register	[Yes / No]
Submission confirmation retained	[Yes / No]
Access permissions reviewed for the retained pack	[Yes / No]
Archive completed by	[Name]
Archive completion date	[Date]